

Plan de Respuesta a Incidentes de Ransomware

Basado en el Marco NIST

Caso: TechCo

Joao Paulo Medeiros - 4Geeks Academy

1. Identificación

La función de identificación consiste en conocer qué activos tiene la empresa, cuáles son los más importantes y cuáles podrían ser el objetivo de un ataque.

1.1 Activos críticos de TechCo

Los activos críticos son aquellos recursos que, si se ven afectados, impactan directamente en el funcionamiento de la empresa. En el caso de TechCo, los activos más importantes son:

Activo	Descripción	Nivel de Criticidad
Servidor de archivos	Almacena documentos y datos operativos del día a día	Alto
Base de datos de clientes	Contiene información personal y financiera de los clientes	Muy Alto
Sistemas de backup	Copias de seguridad de todos los datos de la empresa	Alto
Red interna	Infraestructura que conecta todos los sistemas	Alto
Correo corporativo	Canal de comunicación utilizado para el ataque inicial	Medio
Equipos de los empleados	Ordenadores desde los que se accede a los sistemas	Medio

1.2 Vulnerabilidades que facilitaron el ataque

Durante el análisis del incidente, se identificaron las siguientes vulnerabilidades que permitieron que el ataque tuviera tanto impacto:

- Falta de segmentación de red: Todos los sistemas estaban conectados entre sí, lo que permitió que el ransomware se propagara libremente.
- Ausencia de formación en ciberseguridad: El empleado que abrió el correo de phishing no supo reconocer las señales de alerta.
- Backups conectados a la misma red: Al estar en la misma red, los backups también fueron cifrados por el ransomware.
- Sin monitoreo activo: No había herramientas que alertaran sobre comportamientos inusuales en tiempo real.
- Sin filtros de correo avanzados: El correo de phishing llegó a la bandeja de entrada sin ser bloqueado.

2. Protección

La función de la Protección se centra en implementar medidas preventivas para reducir la posibilidad de que un ataque como este vuelva a ocurrir, o que si ocurre, tenga el menor impacto posible.

2.1 Medidas preventivas recomendadas

2.1.1 Segmentación de la red

Dividir la red en zonas separadas para que, si un sistema es comprometido, el ataque no pueda propagarse fácilmente al resto. Por ejemplo, los backups deben estar en una red completamente separada y sin conexión directa a los sistemas de producción.

2.1.2 Copias de seguridad offline

Mantener copias de seguridad fuera de la red (en discos externos o en la nube con acceso restringido), siguiendo la regla 3-2-1: tener 3 copias de los datos, en 2 tipos de almacenamiento diferentes, y 1 de ellas fuera de las instalaciones (offsite).

2.1.3 Formación y concienciación de empleados

Realizar talleres y formaciones periódicas para que los empleados aprendan a identificar correos de phishing y otras amenazas comunes. Se pueden hacer simulaciones de phishing para practicar.

2.1.4 Filtros de correo y antivirus

Implementar soluciones de filtrado de correo que detecten y bloqueen mensajes sospechosos antes de que lleguen a los empleados. Además, mantener los antivirus y sistemas operativos actualizados en todos los dispositivos.

2.1.5 Control de accesos

Aplicar el principio de mínimo privilegio: cada empleado solo debe tener acceso a los sistemas y archivos que necesita para su trabajo. De esta forma, si un usuario es comprometido, el daño queda limitado.

2.1.6 Autenticación de doble factor (2FA)

Añadir una segunda capa de seguridad al iniciar sesión, de modo que incluso si un atacante obtiene una contraseña, no pueda acceder sin el segundo factor de verificación (por ejemplo, un código enviado al móvil).

Medida	Objetivo	Prioridad
Segmentación de red	Limitar la propagación del ransomware	Alta
Backups offline	Garantizar la recuperación de datos	Alta
Formación a empleados	Reducir el riesgo de phishing	Alta
Filtros de correo	Bloquear correos maliciosos	Media
Control de accesos	Limitar el impacto de una brecha	Media
Autenticación 2FA	Proteger el acceso a los sistemas	Media

3. Detección

La función de Detección busca identificar lo antes posible cuando un ataque está ocurriendo. En el caso de TechCo, el ataque solo fue detectado cuando los empleados notaron que no podían abrir sus archivos, lo que indica una detección muy tardía.

3.1 Herramientas y métodos de detección recomendados

- Sistema de Detección de Intrusiones (IDS): Una herramienta que monitorea el tráfico de la red y genera alertas cuando detecta comportamientos inusuales, como un volumen anormalmente alto de archivos cifrados.
- Monitoreo de registros (logs): Revisar de forma regular los registros de actividad de los sistemas para detectar accesos no autorizados o comportamientos sospechosos.
- Alertas automáticas: Configurar el sistema para que envíe notificaciones automáticas al equipo de seguridad cuando se detecten anomalías, como múltiples intentos de acceso fallidos.
- Análisis de comportamiento de usuarios (UEBA): Detectar cuando un usuario accede a recursos fuera de lo habitual, lo que podría indicar que su cuenta ha sido comprometida.
- Escáneres de vulnerabilidades: Herramientas que analizan los sistemas periódicamente para detectar puntos débiles antes de que los atacantes los aprovechen.

3.2 Protocolo de alerta temprana

Para mejorar la detección en fases tempranas, TechCo debería implementar el siguiente flujo básico:

1. El sistema de monitoreo detecta una anomalía (por ejemplo, un aumento repentino en el cifrado de archivos).
2. Se genera una alerta automática que llega al equipo de seguridad en tiempo real.
3. El equipo evalúa si se trata de una amenaza real o de una falsa alarma.
4. Si se confirma la amenaza, se activa el Plan de Respuesta al Incidente.

4. Respuesta

La función de Respuesta define los pasos concretos que el equipo debe seguir una vez que se confirma que un ataque está ocurriendo. El objetivo es contener el daño lo antes posible y evitar que se extienda.

4.1 Pasos a seguir durante el incidente

1. Confirmación del incidente: Verificar que se trata realmente de un ataque de ransomware y no de otro tipo de fallo técnico.
2. Aislamiento de los sistemas afectados: Desconectar inmediatamente de la red los equipos y servidores comprometidos para evitar que el ransomware siga propagándose.
3. Notificación interna: Informar al equipo directivo, al área legal y al equipo de TI sobre el incidente.
4. Notificación externa: Si hay datos de clientes afectados, se debe notificar a las autoridades competentes y, en caso necesario, a los propios clientes, según lo exija la ley.
5. Preservación de evidencias: Documentar todo lo ocurrido (capturas de pantalla, registros de actividad) para el análisis posterior y posibles investigaciones legales.
6. Análisis del ataque: El equipo de seguridad investiga cómo entró el ransomware, qué sistemas afectó y qué datos podrían haber sido comprometidos.

4.2 Roles y responsabilidades

Para que la respuesta sea efectiva, cada persona debe saber qué le toca hacer:

Rol	Responsabilidad
Responsable de TI / Seguridad	Aislar los sistemas, analizar el ataque y coordinar la respuesta técnica
Dirección / Gerencia	Tomar decisiones estratégicas y aprobar comunicaciones externas
Área Legal	Evaluar obligaciones legales de notificación y gestión del incidente
Comunicación / RRHH	Informar a los empleados y gestionar la comunicación interna
Atención al cliente	Gestionar las comunicaciones con clientes afectados si fuera necesario

4.3 ¿Se debe pagar el rescate?

La recomendación general de las autoridades de ciberseguridad es NO pagar el rescate, por varias razones:

- No garantiza que los atacantes devuelvan el acceso a los datos.
- Financia a grupos criminales y fomenta futuros ataques.
- En algunos países puede ser ilegal pagar a ciertos grupos criminales.

En el caso de TechCo, la decisión correcta sería no pagar y centrar los esfuerzos en la recuperación desde los backup (si están disponibles) y en la restauración de los sistemas.

5. Recuperación

La función de Recuperación define cómo TechCo puede volver a operar con normalidad después del ataque, minimizando el tiempo de inactividad y garantizando que los datos se recuperen de forma segura.

5.1 Pasos para la recuperación

1. Verificar los backups disponibles: Identificar qué copias de seguridad no fueron afectadas por el ransomware. En el caso de TechCo, como los backups estaban en la misma red, es posible que también estén cifrados, lo que resalta la importancia de tenerlos offline.
2. Limpiar los sistemas comprometidos: Antes de restaurar los datos, hay que asegurarse de eliminar completamente el ransomware de todos los sistemas afectados. Esto puede requerir formatear los equipos.
3. Restaurar los datos desde los backups limpios: Recuperar la información desde las copias de seguridad que no hayan sido comprometidas.
4. Verificar la integridad de los sistemas restaurados: Comprobar que los sistemas funcionan correctamente y que no quedan rastros del ransomware antes de volver a conectarlos a la red.
5. Reanudar operaciones de forma gradual: Ir recuperando los servicios poco a poco, empezando por los más críticos, y monitorizando de cerca que todo funcione con normalidad.
6. Comunicación con clientes y partes interesadas: Informar sobre el estado de la recuperación y las medidas tomadas para evitar futuros incidentes.

5.2 Plan de continuidad del negocio

Para que TechCo pueda seguir operando incluso durante un ataque, es recomendable tener un Plan de Continuidad del Negocio (BCP) que incluya:

- Sistemas alternativos de trabajo para que los empleados puedan continuar sus tareas desde otros dispositivos o ubicaciones.
- Procedimientos manuales para los procesos más críticos en caso de que los sistemas digitales estén caídos.
- Contactos de emergencia actualizados: lista de todas las personas clave a las que avisar en caso de incidente.
- Acuerdos con proveedores de servicios de recuperación ante desastres (DRaaS) para una restauración más rápida.

6. Mejora Continua

Una vez superado el incidente, es fundamental aprender de lo ocurrido para mejorar la seguridad de la empresa y evitar que el mismo tipo de ataque vuelva a tener éxito. Esta fase no aparece como función propia del Marco NIST, pero es una parte esencial de cualquier plan de seguridad bien estructurado.

6.1 Análisis post-incidente (lecciones aprendidas)

Después de que la situación esté controlada, el equipo debe reunirse para analizar todo lo que ocurrió y responder preguntas como:

- ¿Cómo entró el ransomware? ¿Qué falló en la detección?
- ¿Cuánto tiempo tardamos en detectar el ataque y en reaccionar?
- ¿Las medidas de protección existentes fueron suficientes?
- ¿Qué datos o sistemas se vieron más afectados y por qué?
- ¿El equipo sabía qué hacer cuando ocurrió el incidente?

Las respuestas a estas preguntas deben documentarse en un informe de lecciones aprendidas que sirva de base para mejorar el plan.

6.2 Acciones de mejora propuestas para TechCo

Área de mejora	Acción propuesta	Plazo
Infraestructura de red	Implementar segmentación de red y aislar los backups	Inmediato
Copias de seguridad	Crear backups offline siguiendo la regla 3-2-1	Inmediato
Formación	Realizar talleres de phishing para todos los empleados	1 mes
Monitoreo	Instalar un sistema IDS y configurar alertas automáticas	2 meses
Control de accesos	Revisar y aplicar el principio de mínimo privilegio	1 mes
Plan de respuesta	Actualizar y practicar el plan con simulacros periódicos	Trimestral

6.3 Simulacros y pruebas periódicas

Para que el plan funcione de verdad cuando se necesite, es importante practicarlo regularmente. Se recomienda:

- Realizar simulacros de incidentes al menos una vez al año para que el equipo sepa cómo reaccionar.
- Probar los backups periódicamente para verificar que se pueden restaurar correctamente.
- Revisar y actualizar el plan cada vez que haya cambios importantes en la infraestructura o tras cada incidente.

Conclusión

El caso de TechCo muestra bien cómo un error pequeño, como abrir un correo de phishing, puede causar un problema enorme para toda la empresa. Con este plan buscamos que algo así no vuelva a pasar, o que si pasa, el impacto sea mucho menor.

Usando el Marco NIST como guía, pudimos organizar las ideas y cubrir todas las áreas importantes: saber qué proteger, cómo protegerlo, cómo detectar un ataque a tiempo, qué hacer cuando ocurre y cómo volver a la normalidad después.

Las cosas más urgentes que TechCo debería hacer son:

- Separar la red para que un ataque no se propague a todos los sistemas.
- Tener backups fuera de la red, para poder recuperar los datos si pasa algo.
- Formar a los empleados para que sepan identificar correos sospechosos.
- Instalar algún sistema de monitoreo para detectar ataques antes de que sea tarde.
- Tener claro quién hace qué cuando ocurre un incidente.

Con estas mejoras, TechCo estaría en una posición mucho mejor para enfrentar futuros ataques.